

Catatan singkat: 5 serangan

Invoice Lab lokal | Dendi Zuckergates

Siapkan: lab sudah aktif. PowerShell dibuka di folder **lab**.

Web: localhost:8081 rentan | :8082 query-fixed | :8083 hardened.

Login tiap versi: alice / **Lab-A-2026!**

S1 / SQL injection - kolom pencarian web

```
' OR '1'='1' --
```

Tambahkan **spasi setelah --**. Coba di ketiga versi.

Target: 8081 = 3 invoice; 8082/8083 = 0. Cari **O'Reilly** di 8082/8083: INV-003.

S2 / IDOR - kolom detail invoice, tetap login Alice

```
INV-002
```

Target: 8081/8082 = 200, invoice Bob terbuka; 8083 = 404.

Pembanding: minta INV-001 di 8083, harus 200.

S3 / Penyalahgunaan hak akun database - PowerShell

```
docker compose --profile tools run --rm tester python tests/attacks.py --scenario S3
```

Target: admin bisa baca internal dan UPDATE sementara lalu rollback.

Runtime menolak keduanya dengan **42501**; SELECT invoice tetap bisa.

S4 / Password valid dari sumber terlarang - PowerShell

```
docker compose --profile tools run --rm untrusted
```

Target: pg_hba.conf menolak **172.30.26.30**, bukan timeout/password salah.

Pembanding: tester .40 berhasil SELECT pada S3.

S5 / Password lama setelah rotasi - PowerShell

```
docker compose --profile tools run --rm tester python tests/attacks.py --scenario S5
```

Target: password lama ditolak untuk **koneksi baru** setelah rotasi;

password saat ini diterima dan aplikasi tetap bekerja.

Retest semua skenario

```
.\lab.ps1 Attacks
```

Target: FIVE SCENARIOS: 5/5. Bukti: **lab/evidence/attacks.json**.

Jalankan perintah berurutan. Jangan menjalankan Test, Attacks, atau S5 bersamaan; tunggu selesai. Semua target hanya lab lokal yang disediakan.